Course Code: ITA1439 **Course Name: Ethical Hacking**

Slot: A

CO1 – ASSIGNMENT_1

Nature of Assignment: Individual **Duration: 1 Week** **Total Marks: 50**

Student Name: P Poojitha **Reg. No: 192371048**

CO1: Apply the foundational concepts of ethical hacking, including the types of hackers, ethical principles, legal frameworks, and the role of responsible disclosure in cybersecurity.

Assignment Title: Design and Develop a Complete Ethical-Hacking Engagement Framework for a University's Authorized Security-Assessment Programme.

Scenario - University Authorized Security-Assessment Programme

A university is establishing an Authorized Security-Assessment Programme to test the security of its student portal, learning-management system, email service and campus network before a major upgrade. The programme must cover approximately 20 systems and 50 staff initially, but the framework is expected to remain usable as the programme grows to the whole university and begins to include external, third-party assessors.

The management has not yet fixed how ethical-hacking engagements will be governed. Testing may be requested by different departments, carried out by internal staff or external testers, and may touch systems that hold personal data. The team is concerned that an unstructured approach may lead to unauthorized access, legal exposure, damage to live systems, unclear scope or uncoordinated disclosure of discovered vulnerabilities.

You have been appointed as the Ethical-Hacking Governance Team. Your responsibility is not merely to describe hacking tools. You must investigate the requirements, design a complete engagement framework, construct reusable components and documents, integrate the different parts, validate the design through a walkthrough and defend the final framework using evidence.

The final framework must clearly distinguish between what is authorized, what is legal, and what is appropriate for the university. The team is expected to make governance decisions independently and justify why the framework is suitable for the given scenario. No live exploitation is performed; all work stays at the design, documentation and isolated-lab level.

Design Challenge

Create and validate an integrated ethical-hacking engagement framework for the university programme. The framework must define how an engagement is authorized, how scope and rules of engagement are

set, how the relevant laws are respected, how different types of attackers are modelled, how discovered vulnerabilities are disclosed responsibly, and how an isolated lab is used where hands-on testing is required.

Your final design must be usable in practice and must demonstrate interaction among the selected components rather than treating each document or rule as an isolated example. Every major governance decision must be supported by evidence and a clear explanation of the trade-offs involved.

TASK 1 – Formulate the Enquiry and Framework Blueprint 4 Marks

• Convert the scenario into a formal set of engagement-governance requirements. Identify the systems in scope, the stakeholders, the expected activities and the constraints.

• Create a framework blueprint showing how authorization, scope, legal compliance, threat modelling, lab testing and disclosure will cooperate in the proposed programme.

• Formulate at least four enquiry questions that your framework must answer, such as who authorizes a test, what is in scope, which laws apply and how findings are disclosed.

• Define at least five design criteria and use them as acceptance criteria for the final framework.

Evidence Expected

A requirements-to-governance blueprint, enquiry questions, design criteria and a clear rationale showing how the proposed framework addresses the scenario.

TASK 2 – Design a Hacker Threat Model and Classification 4 Marks

• Design a classification of the types of hackers relevant to the university, such as white-hat, black-hat, grey-hat, script kiddie, hacktivist, insider and state-sponsored actors.

• Map each type to its motivation, typical capability and likely targets within the university.

• Establish clear criteria and naming so that an actor can be classified consistently.

• Demonstrate at least two alternative ways of classifying one borderline actor, then choose and justify the final classification.

Evidence Expected

A documented hacker threat model, classification criteria, a mapping table, rejected alternatives and a justified final classification.

TASK 3 – Create an Ethics and Code-of-Conduct Module **4 Marks**

• Define the ethical principles that govern an authorized engagement, such as written authorization, agreed scope, confidentiality, integrity, avoiding harm and honest reporting.

• Design rules or checks that help detect or prevent unethical actions during an engagement.

• Construct scenario cases containing acceptable, borderline and unacceptable actions and show how the code of conduct responds to each.

• Explain how the module preserves trust and keeps the engagement lawful and professional.

Evidence Expected

A reusable code-of-conduct module, decision rules, scenario test cases and evidence that the rules separate acceptable from unacceptable actions.

TASK 4 – Construct a Legal-Compliance Mapping **4 Marks**

• Map the engagement to the relevant provisions of the Information Technology Act, 2000 on unauthorized access and data, and compare them with an international law such as the Computer Fraud and Abuse Act.

• Build a table of offences, obligations and penalties related to unauthorized access and data protection.

• Connect each legal requirement to a specific control in the engagement framework.

• Decide and justify which legal requirements apply when a test touches systems that hold personal data.

Evidence Expected

A legal-compliance mapping, an offences-and-penalties table, the controls linked to each requirement and a justified conclusion on which laws apply.

TASK 5 – Create a Scope and Rules-of-Engagement Document **4 Marks**

• Design a scope and rules-of-engagement (RoE) document that defines in-scope and out-of-scope systems, testing windows, permitted and prohibited techniques and escalation paths.

• Create rules for recording and verifying the written authorization behind each engagement.

• Establish clear naming and boundaries so that an out-of-scope request can be detected.

• Construct at least one transformation of the RoE into a pre-engagement checklist.

Evidence Expected

A complete RoE document, authorization-verification rules, scope boundaries and a derived pre-engagement checklist.

TASK 6 – Build an Authorization and Disclosure Layer **5 Marks**

• Create an authorization workflow covering the request, approval, written sign-off and recording of each engagement.

• Design a responsible (coordinated) disclosure process with a reporting format, remediation window and timeline, and compare it with full disclosure and bug-bounty approaches.

• Develop operations for logging approvals and status updates and for deciding when disclosure may proceed.

• Create rules for choosing between coordinated and full disclosure for a given finding.

• Demonstrate that this layer interacts correctly with the rules-of-engagement and legal-compliance components.

Evidence Expected

An authorization workflow, a responsible-disclosure process, logging and decision operations, disclosure rules and evidence of interaction with the other components.

TASK 7 – Design an Isolated Ethical-Hacking Lab **5 Marks**

• Design a safe, isolated lab using a Kali Linux machine and one or more authorized target machines on a host-only network with reserved addresses such as 192.168.56.0/24.

• Specify the components, roles and connectivity of the lab and the steps used to record its configuration.

• Develop at least two operations, such as verifying connectivity between the machines and recording the lab setup.

• Construct a small comparison between a host-only and a NAT lab network and justify the chosen design.

• Explain how the lab keeps all testing authorized and contained within the isolated environment.

Evidence Expected

An isolated-lab design, a component and connectivity specification, verification operations, a comparison of network options and a justified final lab model.

TASK 8 – Develop a Reusable Document Library **5 Marks**

• Create a minimum of four reusable engagement documents supporting the framework, including at least one authorization form and one finding report.

• Use sensible default fields where appropriate and explicitly design the content of each document.

• At least one document, such as the finding report, must produce a structured output that integrates with another component of the framework.

• Create test entries that demonstrate valid, boundary and invalid inputs and document the expected result.

Evidence Expected

A reusable document library, documented fields, a structured report output, test entries and evidence of integration with the framework.

TASK 9 – Integrate, Test and Refine the Framework **5 Marks**

• Integrate the components created in Tasks 2-8 into one coherent engagement framework.

• Construct a realistic walkthrough of an authorized assessment from request and authorization, through testing in the isolated lab, to responsible disclosure.

• Design systematic test cases covering missing authorization, out-of-scope requests, legal conflicts and delayed disclosure.

• Record the problems encountered during the walkthrough and show how the framework was refined to address them.

Evidence Expected

A reproducible integrated framework, a workflow walkthrough, systematic test cases, refinement evidence and a final corrected framework.

TASK 10 – Create a Scalability and Governance Evaluation 5 Marks

• Construct scenarios representing a small programme (one department) and a large programme (the whole university with external assessors), with the number of systems and testers involved.

• Experiment with at least three important processes from the framework and record meaningful measures such as approval turnaround, scope coverage or the number of steps.

• Create a comparison table and at least one suitable chart or structured visualization.

• Use the evidence to refine the governance of the framework rather than simply reporting the measures.

Evidence Expected

A reproducible evaluation setup, a comparison table, a visualization, an interpretation and evidence of at least one governance refinement based on the results.

TASK 11 – Defend the Framework Under a Changed Requirement 5 Marks

• Changed requirement: the university now runs continuous and third-party assessments with stricter data-protection rules and a shorter disclosure timeline, and needs the framework to remain easy to govern and extend.

• Create a revised version of your framework by deciding which components should be retained, modified, replaced or redesigned.

• Construct at least one new or modified component that directly addresses the changed requirement and show how it integrates with the existing framework.

• Defend the final framework using evidence from your walkthrough, scalability evaluation, legal mapping and disclosure process.

• Identify at least two trade-offs or limitations that remain in your final design and propose future improvements.

Evidence Expected

A revised framework, demonstrated adaptation, an evidence-based defence, explicit trade-offs and a clear explanation of how the final design satisfies the changed requirements.

MARK DISTRIBUTION

Task	Marks
TASK 1 – Formulate	4
TASK 2 – Design	4
TASK 3 – Create	4
TASK 4 – Construct	4
TASK 5 – Create	4
TASK 6 – Build	5
TASK 7 – Design	5
TASK 8 – Develop	5
TASK 9 – Integrate	5
TASK 10 – Create	5
TASK 11 – Defend	5
TOTAL	**50**

TASK 1 – Formulate the Enquiry and Framework Blueprint

1.1 Governance requirements

Requirement ID	Requirement	Proposed solution
GR-01	Testing must be authorized.	Written approval before every engagement.
GR-02	Testing scope must be clear.	Maintain an approved system inventory and scope document.
GR-03	Personal data must be protected.	Apply data minimization, access controls and confidentiality rules.
GR-04	Testing must not disrupt university services.	Define testing windows, rate limits and emergency stop procedures.
GR-05	Vulnerabilities must be reported responsibly.	Use a coordinated disclosure process.
GR-06	Testing must be repeatable.	Use reusable templates, checklists and laboratory procedures.
GR-07	The programme must support growth.	Use centralized records and standardized workflows.

1.2 Systems and stakeholders

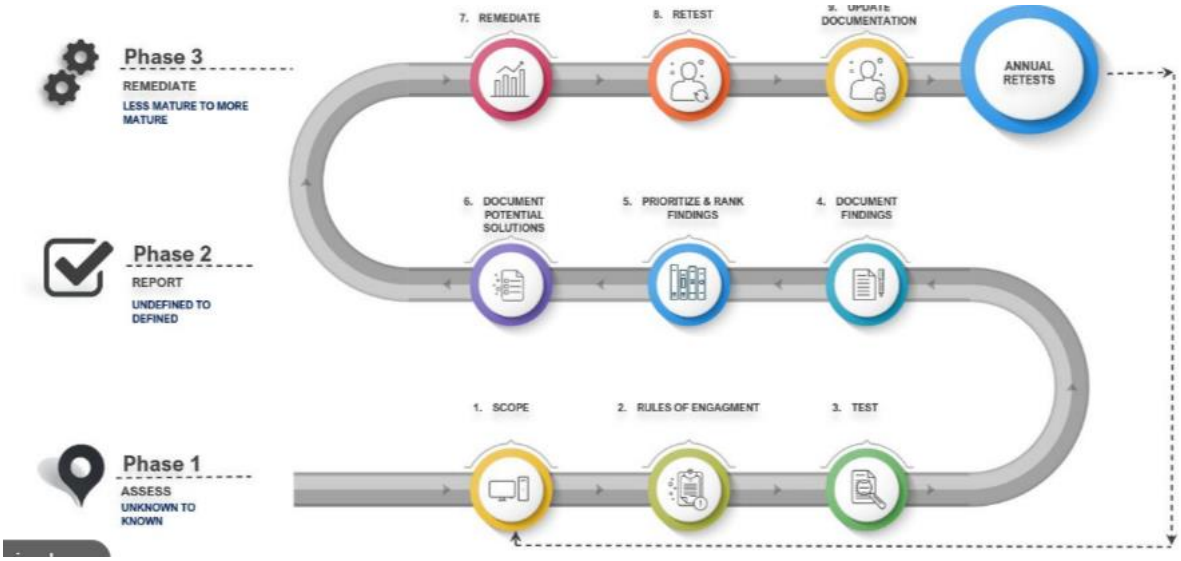
Systems in scope:

- Student portal
- Learning-management system
- University email service
- Campus network
- Approximately 20 systems during the initial programme

Stakeholders:

Stakeholder	Responsibility
University management	Approves programme policies and major risks.
IT department	Maintains systems and approves technical scope.
Security team	Plans, conducts and documents assessments.
Data Protection Officer (DPO)	Reviews personal-data protection requirements.
Internal or external testers	Conduct authorized testing.
System owners	Approve testing of their systems and coordinate remediation.

1.3 Framework blueprint



The components work together. Authorization determines whether testing can begin, the scope document defines the permitted activities, and legal and ethical reviews establish the boundaries. Findings from the assessment enter the disclosure process, which leads to remediation and retesting.

1.4 Enquiry questions

1. Who has the authority to approve a security assessment?
2. Which university systems and activities are included in the approved scope?
3. Which laws and data-protection obligations apply?
4. How should different types of attackers be classified?
5. How should vulnerabilities be reported, remediated and disclosed?
6. How can the framework remain effective when the programme expands?

1.5 Design criteria and acceptance criteria

Design criterion	Acceptance criterion
Authorization	Every engagement has recorded written approval.
Scope control	Every tested asset is listed in the approved scope.
Legal compliance	Applicable legal requirements are mapped to controls.
Ethical conduct	All testers agree to the code of conduct.
Data protection	Personal data is minimized and protected.
Disclosure	Every finding has an owner, severity and disclosure status.

Scalability	The framework supports internal and external assessors.

TASK 2 – Design a Hacker Threat Model and Classification

2.1 Hacker classification

Hackers can be classified according to their authorization, intent, capability and methods.

Hacker type	Motivation	Typical capability	Likely university target
White-hat	Improve security	Authorized security assessment	Student portal, LMS
Black-hat	Financial gain or malicious activity	Unauthorized access and data theft	Student records, email
Grey-hat	Curiosity or recognition	May test systems without permission	Public-facing university services
Script kiddie	Entertainment or attention	Uses existing tools with limited understanding	Login pages, public services
Hacktivist	Political or social cause	Disruption or unauthorized access	University website, email
Insider	Personal benefit, revenge or negligence	Existing legitimate access	Student database, internal systems
State-sponsored	Intelligence or strategic objectives	Advanced, well-resourced operations	Research systems, sensitive records

2.2 Classification criteria

The following criteria are used:

1. Authorization: Was written permission obtained?
2. Intent: Is the activity intended to improve security or cause harm?
3. Capability: Is the actor using basic, intermediate or advanced techniques?
4. Target: Is the activity directed at public services, internal systems or sensitive data?
5. Conduct: Does the actor respect scope and confidentiality?

Authorization and conduct are the most important criteria when distinguishing ethical hacking from unauthorized activity.

2.3 Borderline actor classification

Scenario: A security researcher discovers a weakness in the university's public website without permission, confirms that the weakness exists and informs the university.

Possible classifications:

- Grey-hat: The researcher acted without authorization but reported the weakness without an apparent malicious purpose.
- Black-hat: The researcher deliberately accessed information beyond what was necessary or used the weakness for personal gain.

Final classification: Grey-hat, assuming the researcher did not misuse information or cause harm.

The classification may change if further evidence shows malicious intent or unauthorized data access.

Justification: Ethical hacking requires authorization. Good intentions alone do not make an unauthorized assessment ethical or lawful.

TASK 3 – Create an Ethics and Code-of-Conduct Module

3.1 Code of conduct

Every tester must agree to the following principles:

1. Obtain written authorization before testing.
2. Follow the approved scope and testing schedule.
3. Protect university information and personal data.
4. Avoid unnecessary disruption or damage.
5. Use only approved testing methods.
6. Report findings honestly and accurately.
7. Maintain confidentiality.
8. Stop testing when an unexpected risk is identified.
9. Report vulnerabilities through the approved disclosure channel.
10. Cooperate with remediation and retesting.

3.2 Ethical decision rules

Situation	Decision
Activity is authorized, in scope and safe.	Permit the activity.
Activity is authorized but creates unexpected risk.	Pause and obtain approval.
Activity is outside the approved scope.	Reject the activity until scope is formally updated.
Activity could expose personal data unnecessarily.	Stop and consult the DPO.
Activity is prohibited by the RoE.	Do not perform it.

3.3 Scenario test cases

Scenario	Classification	Response
Tester checks an approved login page during the testing window.	Acceptable	Continue and record the result.

Tester requests permission to extend testing to another system.	Borderline	Pause until written approval is received.
Tester accesses student records without authorization.	Unacceptable	Stop testing, secure the evidence and escalate.
Tester discovers a critical vulnerability and reports it immediately.	Acceptable	Initiate the urgent disclosure process.

The code of conduct protects trust between the university and testers by ensuring that all activities remain authorized, proportionate and professionally managed.

TASK 4 – Create a Legal-Compliance Mapping

The university is located in India. Therefore, Indian law is the primary legal framework for its assessment programme.

4.1 Relevant legal provisions

Law	Relevant provision	Requirement	Framework control
Information Technology Act, 2000	Section 43	Unauthorized access, copying or damage may create civil liability.	Written authorization and scope verification.
Information Technology Act, 2000	Section 66	Certain acts under Section 43 become criminal offences when committed dishonestly or fraudulently.	Ethical approval and activity logging.
Information Technology Act, 2000	Section 72	Protects information obtained through certain powers under the Act.	Confidentiality and restricted access.
Information Technology Act, 2000	Section 72A	Addresses disclosure of personal information in breach of lawful contractual obligations.	Confidentiality agreements and data handling rules.
Digital Personal Data Protection Act, 2023	Applicable provisions	Regulates processing of digital personal data, subject to commencement and applicable rules.	Data minimization, access control and retention limits.
Computer Fraud and Abuse Act (CFAA), USA	18 U.S.C. § 1030	Addresses specified unauthorized access and related computer offences.	Authorization records and scope enforcement.

4.2 Offences and penalties

Provision	General consequence
IT Act Section 43	Compensation for specified unauthorized computer-related acts.
IT Act Section 66	Imprisonment up to 3 years, or fine up to ₹5 lakh, or both.

IT Act Section 72	Imprisonment up to 2 years, or fine up to ₹1 lakh, or both.
IT Act Section 72A	Imprisonment up to 3 years, or fine up to ₹5 lakh, or both.
CFAA	Criminal penalties vary by offence and circumstances; some offences carry imprisonment of up to 10 years or more.

These provisions are summarized for academic purposes. Actual liability depends on the facts, applicable law and current legal interpretation.

4.3 Legal compliance conclusion

The IT Act applies to the university's systems and relevant activities in India. Where an assessment involves digital personal data, the university must also consider applicable data-protection obligations under the DPDP Act and its rules.

The CFAA is relevant when a test has a sufficient connection to the United States, such as certain US-hosted systems or activities involving US jurisdiction. It does not automatically apply to every university assessment.

Important distinction: Written authorization is essential, but it does not automatically make every testing activity legal or appropriate. Testers must also comply with applicable law, contractual obligations, data-protection requirements and the university's own rules.

TASK 5 – Create a Scope and Rules-of-Engagement Document

5.1 Scope document

Field	Details
Engagement ID	UAS-2026-001
Engagement name	University Security Assessment
Requesting department	University IT Department
Authorized systems	Student portal, LMS, email and approved campus network assets
Testing environment	Isolated laboratory
Testing window	Approved dates and times
Authorized testers	Named internal or external assessors
Approval authority	IT Director and relevant system owners
Data classification	Confidential university information
Emergency contact	Security programme coordinator

5.2 In-scope and out-of-scope systems

In scope:

- Approved student portal test environment

- Approved LMS test environment
- Approved email test environment
- Approved campus-network laboratory assets

Out of scope:

- Unlisted university systems
- Third-party services without written permission
- Personal devices
- Production databases containing real student information
- Systems owned by external organizations without authorization

5.3 Rules of engagement

- Testing must occur only during approved windows.
- Only named testers may participate.
- Testing must remain within the approved system list.
- Denial-of-service testing is prohibited.
- Real student data must not be accessed unnecessarily.
- Any unexpected access to sensitive data must be reported immediately.
- Testing must stop if a system becomes unstable.
- Scope changes require written approval.

5.4 Authorization verification

Before testing begins, the coordinator must verify:

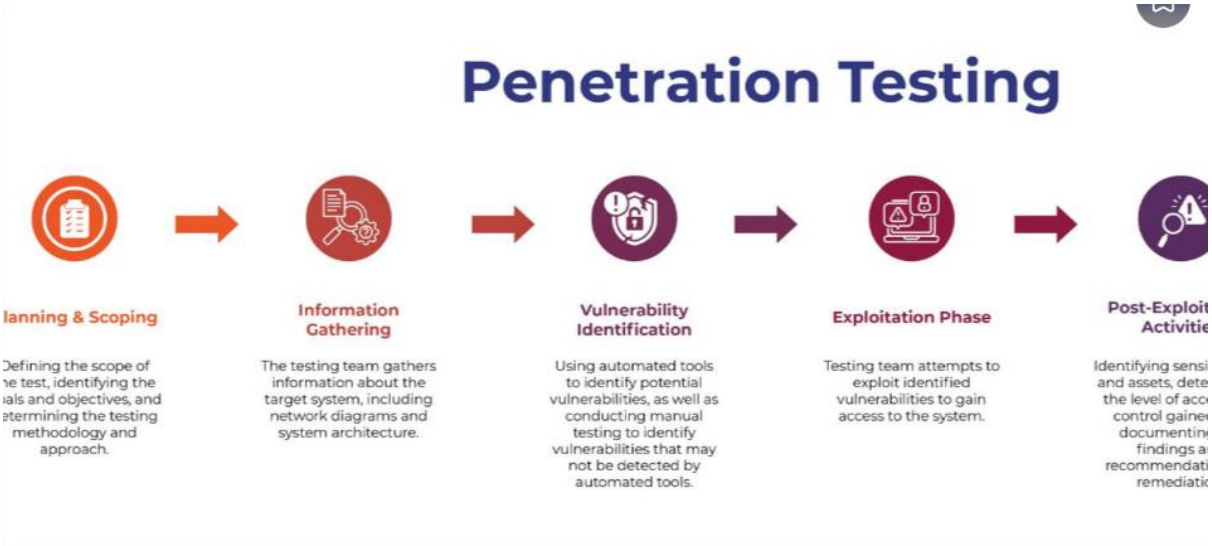
1. The approval document is signed by the correct authority.
2. The engagement ID matches the scope document.
3. The systems and testing dates are clearly listed.
4. The tester's identity and role are recorded.
5. The approval has not expired or been withdrawn.

5.5 Derived pre-engagement checklist

- [x] Written authorization obtained.
- [ ] Scope reviewed and confirmed.
- [x] Legal and data-protection review completed.
- [ ] Testers have signed the code of conduct.
- [ ] Emergency contacts are available.
- [x] Laboratory isolation verified.
- [ ] Testing window confirmed.
- [ ] Disclosure contact assigned.

TASK 6 – Build an Authorization and Disclosure Layer

6.1 Authorization workflow



6.2 Responsible disclosure process

The university will use coordinated vulnerability disclosure (CVD).

Stage	Action	Timeline
Day 0	Vulnerability discovered and reported.	Immediately
Day 1–3	University acknowledges the report.	Within 3 business days
Day 4–7	Security team validates the finding and assigns severity.	Within 7 days
Day 8–30	University develops and applies a remediation.	Target: 30 days
Day 31–45	Retesting and closure.	Target: 45 days
Day 45 onward	Public disclosure only when appropriate and coordinated.	Based on risk and agreement

Critical vulnerabilities require immediate escalation and a faster remediation target.

6.3 Finding report format

Each finding must contain:

- Finding ID
- Engagement ID
- Affected system
- Vulnerability description
- Severity
- Evidence collected
- Potential impact
- Recommended remediation

- Assigned owner
- Disclosure status

6.4 Disclosure models

Model	Description	University decision
Coordinated disclosure	Researcher and organization coordinate remediation and publication.	Preferred approach.
Full disclosure	Vulnerability details are made public immediately.	Used only when justified and legally reviewed.
Bug bounty	Researchers receive rewards for valid findings under a defined policy.	Possible future programme.

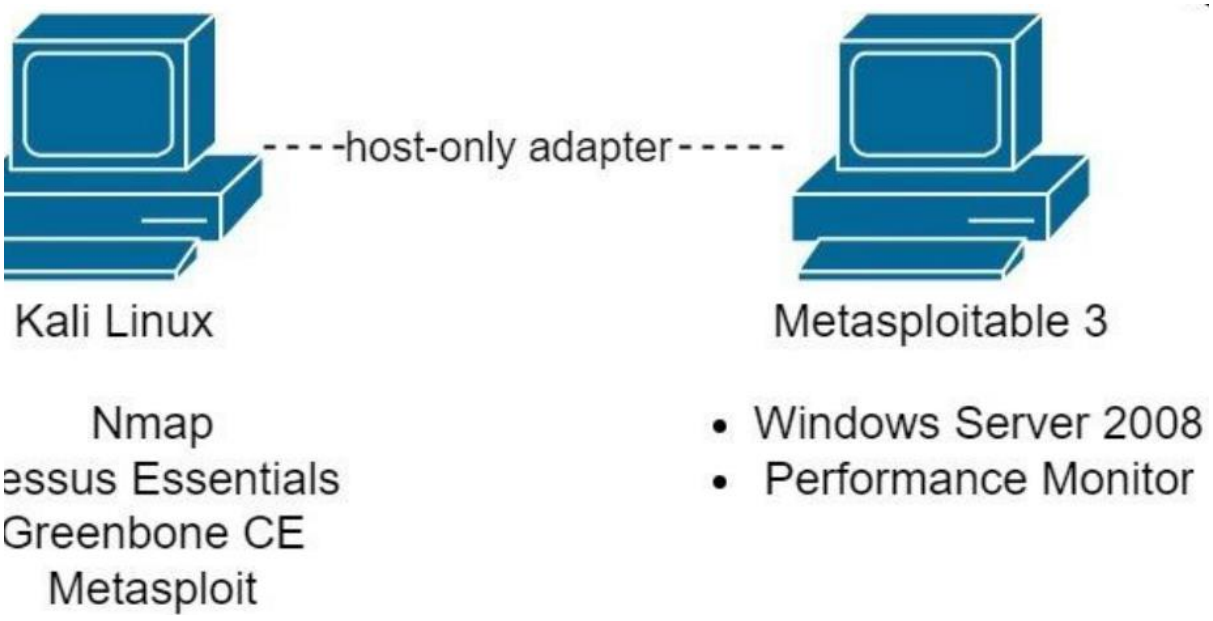
Coordinated disclosure is preferred because it provides the university time to fix vulnerabilities while protecting students and staff.

6.5 Disclosure decision rules

- Critical findings are escalated immediately.
- Public disclosure requires security and legal review.
- Personal data must never be included in public reports.
- A finding cannot be publicly disclosed while doing so would create an unacceptable risk to users.
- Delayed remediation must trigger escalation to university management.

TASK 7 – Design an Isolated Ethical-Hacking Lab

7.1 Laboratory architecture



7.2 Components and connectivity

Component	Role	Example IP
Kali Linux VM	Authorized testing machine	192.168.56.10
Target VM	Deliberately vulnerable lab system	192.168.56.20
Host-only network	Isolated communication between VMs	192.168.56.0/24

7.3 Lab operations

Operation 1: Verify connectivity

The tester confirms that the Kali VM and authorized target VM can communicate within the isolated network.

Operation 2: Record the laboratory configuration

The tester records:

- VM names and operating-system versions
- Network adapter settings
- IP addresses
- Snapshot identifiers
- Approved testing tools
- Date and time of configuration

7.4 Host-only versus NAT

Feature	Host-only	NAT
VM communication	Host and connected VMs	VMs can access external networks through NAT
Internet access	Normally unavailable	Usually available
Isolation	Stronger isolation	Greater external connectivity
Suitability	Preferred for this assignment	Useful when controlled updates are required

Final decision: Use a host-only network because the assignment requires all hands-on testing to remain isolated. NAT is unnecessary for the main testing activities.

TASK 8 – Develop a Reusable Document Library

The following four documents will be maintained as reusable templates.

Document 1: Authorization Form

Field	Description
Engagement ID	Unique assessment identifier
Requesting department	Department requesting the assessment

Systems in scope	Approved assets
Testing dates	Start and end dates
Authorized testers	Names and roles
Approval authority	Name and designation
Signature	Written approval
Approval date	Date of authorization

Document 2: Rules-of-Engagement Form

Fields include engagement ID, approved systems, testing window, permitted activities, prohibited activities, emergency contacts and scope-change procedure.

Document 3: Finding Report

Field	Description
Finding ID	Unique vulnerability identifier
Engagement ID	Related assessment
System	Affected asset
Severity	Critical, High, Medium or Low
Description	Summary of the weakness
Evidence	Safe, redacted supporting information
Impact	Potential consequence
Remediation	Recommended corrective action
Status	Open, In Progress, Resolved or Closed

This document produces a structured finding record that integrates with the authorization and disclosure layer.

Document 4: Engagement Closure Report

Fields include engagement ID, assessment dates, systems tested, findings summary, remediation status, lessons learned, approvals and closure date.

8.1 Document validation

Test entry	Input	Expected result
Valid	Signed authorization with all required fields	Accepted
Boundary	Approval expires on the final testing date	Accepted only within the approved

		period
Invalid	Missing approval signature	Rejected
Invalid	Finding report has no engagement ID	Rejected
Invalid	Scope includes an unapproved system	Rejected

TASK 9 – Integrate, Test and Refine the Framework

9.1 Integrated walkthrough

Scenario: The university requests an assessment of its LMS before a major upgrade.

1. The IT department submits an assessment request.
2. The security team assigns an engagement ID.
3. The system owner approves the scope.
4. The DPO reviews the data-protection requirements.
5. The authorization form and RoE are signed.
6. The testing team prepares the isolated laboratory.
7. The team conducts authorized laboratory testing.
8. A vulnerability is identified and documented.
9. The finding is submitted through the disclosure process.
10. The university remediates the weakness.
11. The tester verifies the correction in the laboratory.
12. The engagement is closed and documented.



9.2 Systematic test cases

Test	Condition	Expected result
TC-01	Missing authorization	Testing is blocked.
TC-02	Out-of-scope system requested	Request is rejected or returned for

approval.

TC-03	Legal review identifies a conflict	Engagement is paused.
TC-04	Critical vulnerability discovered	Immediate escalation occurs.
TC-05	Disclosure deadline is missed	Management escalation is triggered.

9.3 Problems and refinements

Problem identified	Refinement
Different departments use different approval formats.	Introduce a standard authorization form.
Scope changes may be communicated informally.	Require written scope-change approval.
Findings may contain sensitive data.	Require redaction and restricted evidence storage.
External testers may not follow university procedures.	Require onboarding and signed code of conduct.
Disclosure may be delayed.	Introduce deadline monitoring and escalation.

TASK 10 – Create a Scalability and Governance Evaluation

10.1 Introduction

Scalability means the ability of a framework to handle an increasing number of systems, departments and security testers without losing control.

The university framework is evaluated using two scenarios.

10.2 Small Programme

A small programme covers one department.

- Number of systems: 5
- Number of testers: 2
- Number of departments: 1
- Approval: Department head
- Testing: Limited assessment

10.3 Large Programme

A large programme covers the entire university.

- Number of systems: 20 initially, expandable to the whole university.
- Number of testers: 10, including external assessors.
- Number of departments: Multiple departments.
- Approval: Central security governance team.
- Testing: Multiple coordinated assessments.

10.4 Comparison Table

The following are illustrative evaluation results for a simulated programme, not actual measured university data.

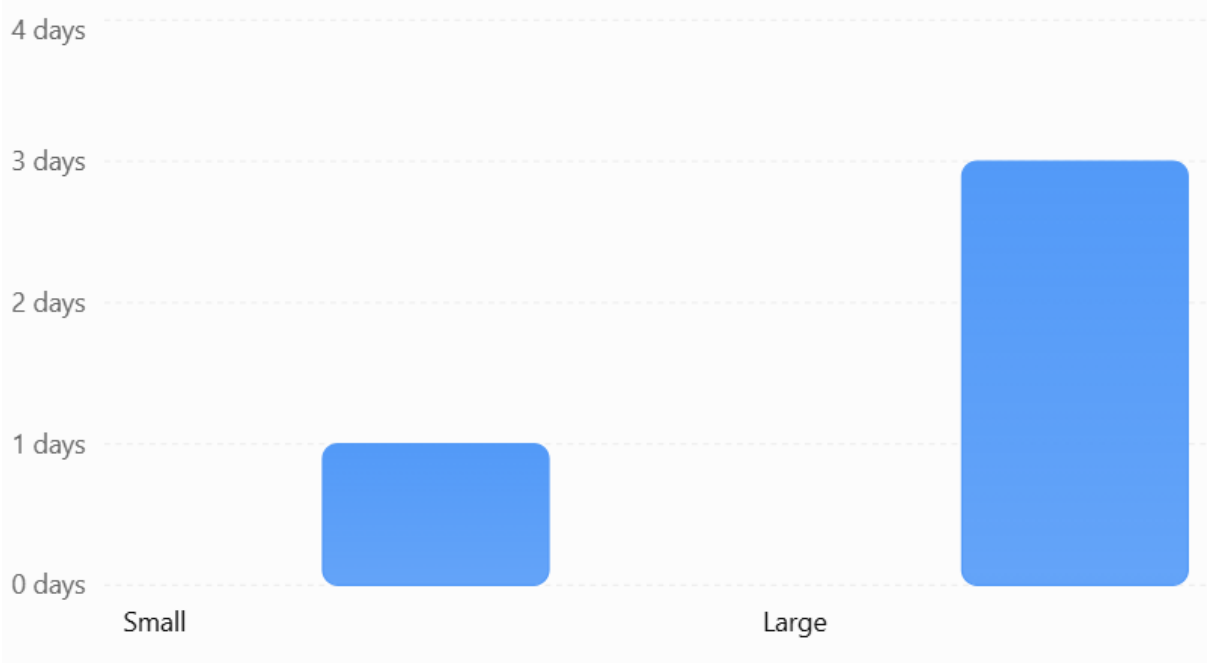
Process	Small Programme	Large Programme
Systems Covered	5	20
Testers	2	10
Approval Time	1 Day	3 Days
Scope Verification	2 Steps	4 Steps
Report Preparation	1 Day	3 Days
Testing Coordination	Simple	Centralized

10.5 Process Evaluation

Three important processes are evaluated:

1. Approval Process: Larger programmes require additional approval and verification.
2. Scope Management: More systems require detailed scope documentation.
3. Disclosure Process: More testers require a common reporting and tracking system.

10.6 Visualization



10.7 Interpretation

- Small programmes can be managed with fewer approval steps.
- Large programmes require centralized management.
- External testers need identity verification.
- A common reporting format reduces confusion.
- Automated tracking helps manage multiple assessments.

10.8 Governance Improvements

Based on this evaluation, the university should:

1. Introduce a central approval system.
2. Maintain a common database for security findings.
3. Provide separate access permissions for internal and external testers.
4. Use standard authorization and reporting forms.
5. Monitor assessment deadlines.

Conclusion: The framework can support both small and large programmes by using centralized governance, standard documents and proper monitoring

.

TASK 11 – Defend the Framework Under a Changed Requirement

11.1 Changed requirement

The university now requires continuous assessments, external assessors, stricter data protection and shorter disclosure timelines.

The framework must therefore support ongoing authorization, stronger monitoring and faster response.

11.2 Revised framework

Component	Decision	Reason
Authorization	Modify	Support recurring assessments with periodic approval renewal.
Scope and RoE	Modify	Maintain an approved asset inventory with clear change controls.
Legal compliance	Retain and strengthen	Add stricter data-protection checks.
Threat modelling	Retain	Continue to identify relevant attacker types.
Ethics module	Retain and strengthen	Require additional third-party training and agreements.
Lab testing	Retain and expand	Support isolated testing for external assessors.
Disclosure	Redesign	Introduce shorter deadlines and automated escalation.
Document library	Modify	Use standardized digital records.
Evaluation	Expand	Monitor approval time, scope coverage and disclosure performance.

11.3 New component: Continuous Assessment Governance

The new component will include:

1. A centralized register of approved systems and engagements.
2. Periodic authorization renewal.
3. Automatic review when a system changes ownership or scope.
4. Mandatory external-assessor agreements.
5. Restricted access to evidence containing personal data.
6. Shorter disclosure deadlines.
7. Escalation when deadlines are missed.

11.4 Integration with existing components

The continuous-assessment component connects to authorization, scope, legal compliance and disclosure.

For example, when a new system is added to the university network, the asset register is updated. The system cannot be tested until its scope is approved, its legal requirements are reviewed and the responsible system owner is identified.

11.5 Trade-offs and limitations

Trade-off	Explanation
Stronger approval controls	Improve security but may increase administrative time.
Shorter disclosure deadlines	Improve response speed but require more staff and resources.
Strict data minimization	Protects personal data but may limit the evidence available for investigation.
Continuous monitoring	Improves coverage but requires reliable automation and ongoing maintenance.